

Recep Tayyip Erdoğan Üniversitesi

Mühendislik ve Mimarlık Fakültesi — Bilgisayar Mühendisliği

CEN429 Güvenli Programlama — Ders İzlenesi

2026-2027 Güz Yarıyılı

Ders Bilgileri

Öğretim üyesi	Dr. Öğr. Üyesi Uğur CORUH
İletişim	ugur.coruh@erdogan.edu.tr — konu satırı [CEN429] ile başlamalıdır
Ofis	F-301
Görüşme saatleri	E-posta ile randevu; ofiste ya da üniversite hesabıyla çevrim içi
Ders günü, saati, dersliği	Cuma 09:00–12:00 · İİBF ve Hukuk Fakültesi Binası, D-402 (ED-K4-2)
Ders web sitesi	https://ucoruh.github.io/cen429-secure-programming/
Ders sınıfı	Her dönem yeni sınıf açılır; sınıf kodu 1. haftada duyurulur
Eğitim dili	Türkçe
Tür / yarıyıl	Seçmeli · 7. yarıyıl
Haftalık saat / kredi / AKTS	Kuramsal 3 saat · Kredi 3 · AKTS 5
Ön koşul	CEN107 Algoritmalar ve Programlama I (eski kodu CE103) — ayrıntılar: Ön gereksinimler

A. Dersin Tanımı

Bu ders, güvenli yazılım geliştirme tekniklerini anlamaya yönelik kapsamlı bir yaklaşım sunar. Öğrenciler arabellek taşması, bellek sızıntıları ve enjeksiyon saldırıları gibi yaygın güvenlik açıklarını ele almak için yazılım koruma yöntemlerini öğrenir: veri güvenliği ve kriptografi, C/C++ ve Java için kod sağlamlaştırma (hardening), çalışma zamanı uygulama öz

koruması (RASP), kod gizleme ve çeşitlendirme, whitebox kriptografi, güvenlik standartları ve sızma testi planlaması. Ders, güvenli yazılım geliştirmedeki gerçek dünya uygulamalarına ve en iyi uygulamalara odaklanır. Her konu hatalı kod → saldırı → düzeltme sırasıyla, derste yapılan uygulamalarla ve bir sertifikasyon sürecinden geçiyormuş gibi yürütülen dönem projesiyle pekiştirilir.

B. Öğrenme Çıktıları

Bu dersi başarıyla tamamlayan öğrenci:

Kod	Öğrenme çıktısı
ÖÇ.1	Yaygın yazılım güvenlik açıklarını (arabellek taşması, enjeksiyon saldırıları, bellek sızıntıları vb.) tanımlar ve sınıflandırır.
ÖÇ.2	Hassas verileri korumak için temel şifreleme yöntemlerini (simetrik/asimetrik, özet fonksiyonları) ve güvenli iletişim ilkelerini (SSL/TLS) açıklar.
ÖÇ.3	Kod sağlamlaştırma tekniklerini (girdi doğrulama, güvenli bellek yönetimi, RASP, kod gizleme/karıştırma) açıklar ve farklı diller (C/C++, Java) için uygular.
ÖÇ.4	Şifreleme ve kimlik doğrulama mekanizmalarını kullanarak güvenli iletişim kanalları kurma prensiplerini açıklar.
ÖÇ.5	Güvenli yazılım tasarımı ilkelerini (en az ayrıcalık, savunma derinliği vb.) ve savunma stratejilerini kullanarak yazılım planı oluşturur.
ÖÇ.6	Yazılım güvenlik açıklarını tespit etmek için temel güvenlik incelemesi ve güvenlik açığı değerlendirme yöntemlerini bilir.
ÖÇ.7	Güvenli programlama standartlarını (örn: ETSI, EMV, FIPS) ve sızma testi planlaması prensiplerini bilir.

Öğrenme çıktılarının program çıktılarına katkısı (0–5)

	PÇ.1	PÇ.2	PÇ.3	PÇ.4	PÇ.5	PÇ.6
ÖÇ.1	–	3	–	5	–	–
ÖÇ.2	–	–	–	3	–	–
ÖÇ.3	–	3	3	3	–	–
ÖÇ.4	–	–	3	3	–	–
ÖÇ.5	–	3	3	3	–	–
ÖÇ.6	–	3	–	3	3	–
ÖÇ.7	–	–	–	3	–	–

PÇ.2 Problem çözme · PÇ.3 Tasarım · PÇ.4 Modern teknik ve araçlar · PÇ.5 Araştırma ve deney · PÇ.8 İletişim · PÇ.9 Toplumsal bilinç · PÇ.11 Etik ve standartlar · PÇ.12 Proje ve risk yönetimi.

C. Haftalık Program

Bütün değerlendirmeler için kural: **proje gösterimleri vize ve final haftalarının hemen öncesindeki haftada; quizler vize ve final haftalarının içinde** yapılır, böylece her öğrenci katılabilir. Konular ritimdeki sırayla işlenir.

Hafta	Tarih	Konular	Öç
1	18.09.2026 (telafi 30.09)	Ders planı ve iletişim. Güvenli programlamaya giriş: güvenlik hedefleri (gizlilik, bütünlük, erişilebilirlik), saldırgan modeli, tehdit modelleme (saldırı ağaçları, STRIDE). Uygulama korumasına genel bakış; arabellek taşmaları ve önleme teknikleri; bellek yönetimi ve güvenlik; korunan kod bölümler ve şifreleme ile güvenli işleme. Uygulama koruma planının hazırlanması.	1, 5
2	25.09.2026	Bilgisayar virüsleri ve zararlı yazılımlar: virüs türleri (program, makro, önyüklem sektörü), solucanlar ve truva atları; virüslere karşı önlemler. Saldırı ağaçları ve güvenlik modelleri (Bell–LaPadula, Biba, Clark–Wilson). Yazılım güvenlik açıklarının sınıflandırılması: CWE ve CVE Top 25, OWASP Top 10, CVE ve CVSS.	1
3	02.10.2026	Veri güvenliği: aktarımda, beklemede ve kullanımda. Şifreleme temelleri (simetrik/asimetrik, özet fonksiyonları, kimlik doğrulamalı şifreleme); SSL/TLS kullanımı ve TLS 1.3 el sıkışması; sertifika sabitleme; whitebox kriptografi uygulamalarına giriş; dinamik anahtar yönetimi ve oturum anahtarları; veri maskeleyme teknikleri; bellekteki hassas verinin güvenli silinmesi.	2, 4
4	09.10.2026	Kod sağlamlaştırma (C/C++): güvenli bellek yönetimi ve güvenli kodlama kuralları (SEI CERT C/C++); arabellek taşması, serbest bırakılmış belleğin kullanımı (use-after-free) ve tamsayı taşması örnekleri; sanitizeler (AddressSanitizer, UndefinedBehaviorSanitizer) ve fuzzing'e giriş; derleyici ve işletim sistemi korumaları (stack canary, ASLR, DEP/NX, CFI, SafeStack); kontrol akışı düzeltme; fonksiyon adı gizleme; bellek tahsisi gizleme; dinamik şifreleme teknikleri.	3
5	16.10.2026	Kod sağlamlaştırma (Java/yorumlanan diller): girdi doğrulama ve enjeksiyon saldırılarına karşı savunma (SQL, komut, yol geçişi; parametrelili sorgular; SEI CERT Oracle Java); ProGuard ve R8 ile kod gizleme; dinamik yöntem gizleme; statik dize gizleme ve koruma; gelişmiş ProGuard kuralları; bağımlılık güvenliği ve yazılım malzeme listesi (SBOM).	3
6	23.10.2026	Çalışma zamanı uygulama öz koruması (RASP) (C/C++): root ve emülatör algılama; APK imza doğrulaması; çalışma zamanında kod bloğu bütünlüğü (checksum) kontrolü; hata ayıklayıcı algılama ve bağlanmayı engelleme; kanca (hook) saldırısı algılama; dinamik bellek koruması ve bellek izleme tespiti; dinamik analiz araçlarına karşı koruma; müdahale algılandığında verilecek yanıtlar.	3
7	30.10.2026	Ara proje gösterimleri ve ara proje raporu teslimi.	1, 2, 3, 5, 7
8	31.10– 08.11.2026	Ara sınav haftası — Quiz-1 (1–6. haftalar).	1, 2, 3
9	13.11.2026	Gelişmiş kod gizleme ve çeşitlendirme: dinamik kontrol akışı gizleme; opak yüklemeler (opaque predicates), sahte kontrol akışları ve ölü kod ekleme; program gizleme teknikleri (veri kodlama, sanallaştırma)	3

Hafta	Tarih	Konular	Öç
		tabanlı gizleme); dinamik fonksiyon çağrılar ve çalışma zamanı optimizasyonları; gizlemenin etkinliğinin ölçülmesi (güç, dayanıklılık, maliyet).	
10	20.11.2026	Sertifika ve kriptografik yöntemler (AES, RSA, PKI): AES ve RSA şifrelemesi, çalışma kipleri ve dolgu; HMAC ile veri bütünlüğü; dijital imza oluşturma ve doğrulama; PKI bileşenleri (CA, RA, sertifika zinciri); X.509 sertifika oluşturma (OpenSSL); sertifika iptali (CRL, OCSP); anahtar dağıtım problemi.	2, 4
11	27.11.2026	Whitebox kriptografi: beyaz kutu ve kara kutu saldırgan modelleri; whitebox AES ve DES uygulamaları (tablo tabanlı gerçekleştirim); whitebox kriptografi ile anahtar koruması; bilinen saldırılar (diferansiyel hesaplama ve hata analizi) ve karşı önlemler; yazılım tabanlı güvenlik çözümleri (ör. SoftHSM ile yazılımsal güvenlik modülü).	2, 3
12	04.12.2026	Güvenlik sertifikasyonları ve sızma testi planlaması: ETSI ve EMV güvenlik standartları; PCI DSS ve ISO/IEC 27001 kapsamındaki güvenlik testleri; güvenlik incelemesi ve zafiyet değerlendirme (kod incelemesi, statik ve dinamik analiz, fuzzing); sızma testi planı: kapsam, kurallar, yöntem (OWASP WSTG ve MASTG, PTES) ve raporlama.	5, 6, 7
13	11.12.2026	Güvenlik gereksinimleri: ETSI, GSMA ve EMV güvenlik gereksinimleri; Ortak Kriterler (ISO/IEC 15408) ve EAL düzeyleri; FIPS 140-3 gereksinimleri; gereksinimlerin yazılım planına ve varlık yönetimine aktarılması.	5, 7
14	18.12.2026	Tigress ve çeşitlendirme: Tigress ile C kaynak kodu dönüşümleri (kontrol akışı düzeltme, sanallaştırma, sabit ve aritmetik kodlama, opak yüklem, fonksiyon bölme ve birleştirme); gizleme yöntemlerinin birleştirilmesi; çeşitlendirme ile her kopya için farklı binary; saldırılara karşı savunma ve gizlenmiş kodun analize dayanıklılığının değerlendirilmesi.	3
15	25.12.2026	Final proje gösterimleri ve final proje raporu teslimi.	1–7
16	04– 17.01.2027	Final sınav dönemi – Quiz-2 (9–14. haftalar).	2–7

Ders notlarında isteğe bağlı okuma olarak işlenecek zenginleştirme konuları: bellek güvenli diller (Rust) ve C/C++ ile birlikte kullanımı, güvenli yazılım geliştirme yaşam döngüsü (NIST SSDF), yan kanal saldırılarına giriş, tersine mühendislik araçlarıyla (Ghidra) gizlenmiş kodun incelenmesi.

D. Kaynaklar, Yazılım ve Donanım

Ana kaynak, ders web sitesindeki ders notlarıdır ve kendi başına yeterlidir. Notlar aşağıdaki ders kitabının tarifleri ile öğretim üyesinin yazılım koruma ve güvenlik sertifikasyonu alanında geliştirdiği kod koruma ve güvenlik yöntemleri üzerine kuruludur; bu yöntemler ilgili haftaların konuları içinde işlenir.

Ders kitabı:

- J. Viega, M. Messier. *Secure Programming Cookbook for C and C++*. O'Reilly, 2003. — Kitaptaki kavramlar ve hata desenleri bugün de geçerlidir; 2003 tarihli API ve algoritmaların güncel karşılıkları (OpenSSL 3, TLS 1.3, AES-GCM, Argon2id vb.) ders notlarında verilir.

Ritimde tanımlı diğer kaynaklar:

- Deitel & Deitel. *C How to Program*, 7. baskı. Prentice Hall, 2013.
- T. H. Cormen, C. E. Leiserson, R. L. Rivest, C. Stein. *Introduction to Algorithms*, 3. baskı. MIT Press.
- J. R. Hanly, E. B. Koffman. *Problem Solving and Program Design in C*.

İleri okuma:

- R. C. Seacord. *Secure Coding in C and C++*, 2. baskı. Addison-Wesley, 2013.
- C. Collberg, J. Nagra. *Surreptitious Software: Obfuscation, Watermarking, and Tamperproofing for Software Protection*. Addison-Wesley, 2009.
- M. Dowd, J. McDonald, J. Schuh. *The Art of Software Security Assessment*. Addison-Wesley, 2006.
- R. Anderson. *Security Engineering*, 3. baskı. Wiley, 2020.
- J.-P. Aumasson. *Serious Cryptography*, 2. baskı. No Starch Press, 2024.
- Açık erişimli standartlar: SEI CERT C/C++ ve Oracle Java güvenli kodlama standartları, OWASP Top 10, ASVS, MASVS ve MASTG, MITRE CWE, NIST FIPS 140-3.

Dizüstü bilgisayar gereklidir. Derste ve projede kendi geliştirme ortamınızı kullanacaksınız: C/C++ derleyicisi (GCC, Clang ya da MSVC), CMake, GoogleTest, OpenSSL 3, SQLite, SoftHSM2, JDK 21 ile ProGuard/R8, Tigris (Linux; Windows'ta WSL2 ya da Docker ile), Git ve bir GitHub hesabı. Android konuları için Android Studio (SDK ve NDK) ile emülatör önerilir. Kurulum adımları 1. haftada ve ders notlarında verilir; proje şablonları sağlanır.

E. Değerlendirme

Dönem boyunca **tek bir proje** yürütülür: seçilen bir konu üzerinde, güvenlik gereksinimlerini karşılayan ve bir sertifikasyon sürecinden geçiyormuş gibi tasarlanan bir C/C++ uygulaması. Projeler bireysel olarak ya da en fazla 4 kişilik takımlarla yapılır; geliştirmeye başlamadan önce GitHub'da proje planı hazırlanıp onaylatılır. Projenin her biri kendi rubriğiyle değerlendirilen iki ara kontrolü vardır: vize kontrolü ve final kontrolü. Ayrıca ara sınav haftasında bir, final döneminde bir quiz yapılır. Proje konuları, gereksinimler, teslimler ve **ayrıntılı vize ve final rubrikleri** (kriterler, puanlar, ilişkili öğrenme çıktıları ve başarı düzeyleri) dersin proje rehberinde verilir.

Değerlendirme	Kod	Ağırlık	Zaman
Proje kontrolü 1 — ara rapor ve gösterim (rubrik)	RAP1	Vizenin %60'ı	7. hafta (30.10.2026)
Quiz-1 (1–6. haftalar)	QUIZ1	Vizenin %40'ı	8. hafta, ara sınav haftası (31.10–08.11.2026)
Proje kontrolü 2 — final rapor ve gösterim (rubrik)	RAP2	Finalin %70'i	15. hafta (25.12.2026)
Quiz-2 (9–14. haftalar)	QUIZ2	Finalin %30'u	16. hafta, final dönemi (04–17.01.2027)

Rubrik kriterleri (ritim): **vize kontrolü** — güvenlik analizi (ÖÇ.1), veri güvenliği (ÖÇ.2), C/C++ kod sağlamaştırma ve RASP teknikleri (ÖÇ.3), proje yönetimi (ÖÇ.5), ara rapor (ÖÇ.7); **final kontrolü** — kriptografi uygulaması (ÖÇ.2), güvenli iletişim (ÖÇ.4), varlık yönetimi (ÖÇ.5), binary uygulama korumaları (ÖÇ.3), güvenlik testi ve birim testleri (ÖÇ.6), güvenlik standartları, final rapor ve sunum (ÖÇ.7).

$$Not_{Vize} = 0.6 RAP1 + 0.4 QUIZ1 \quad Not_{Final} = 0.7 RAP2 + 0.3 QUIZ2$$

$$Başarı Notu = 0.4 Not_{Vize} + 0.6 Not_{Final}$$

İş yükü (AKTS 5 = 125 saat)

Etkinlik	Sayı	Süre	Toplam
Derse Katılım	14	3	42
Bireysel Çalışma (haftalık notlar ve uygulamalar)	14	1	14
Quiz (ara sınav haftası ve final dönemi)	2	2	4
Quiz için Bireysel Çalışma	2	10	20
Proje Hazırlama (vize ve final kontrolleri)	2	16	32
Rapor Hazırlama	2	5	10
Proje Sunma (gösterim ve sorular)	2	1,5	3
Toplam			125

F. Öğretim Yöntemleri

Dersler sınıfta yüz yüze yapılır; anlatım, soru–cevap ve uygulamalı programlama bir arada kullanılır. Her içerik haftası ders notu, sunum, çözümlü örnekler ve kendini sınamaya sorularıyla birlikte gelir; uygulamalar hatalı kod → saldırı → düzeltme sırasıyla, derste verilen yalıtılmış ortamlarda (konteyner ya da sanal makine) yapılır. Derste öğrenilen saldırı teknikleri yalnızca bu ortamlarda ve öğrencinin kendi sistemlerinde denir. Duyurular, kaynaklar ve teslimler ders sınıfında yürütülür. Yoklama alınır.

G. Geç Teslim

Ödev ve projelerin belirlenen tarihlerde teslim edilmesi gerekir. Geç teslimler kabul edilmez. Beklenmedik durumlar en kısa sürede öğretim üyesine bildirilmelidir.

H. Ders Platformu ve İletişim

Bütün duyurular, kaynaklar ve teslimler her dönem yeniden açılan ders sınıfında paylaşılır; sınıf kodu 1. haftada duyurulur. Ders notları, sunumlar ve indirilebilir belgeler ders web sitesindedir. Sınıfı ve üniversite e-postanızı her gün kontrol edin.

I. Akademik Dürüstlük, İntihal ve Kopya

Akademik dürüstlük RTEÜ'nün en önemli ilkelerinden biridir. Akademik dürüstlük ilkelerine aykırı davranışlar ciddi şekilde cezalandırılır.

Sınıf arkadaşlarınızla ya da başkalarıyla "birlikte çalışmak" doğaldır. Bir öğrenci zor bir konuyu ya da bütün dersi daha iyi anlamak için ücretli ya da ücretsiz birinden yardım istemiş olabilir. Peki "birlikte çalışmak" ya da "özel ders almak" ile "akademik dürüstlük ihlali" arasındaki sınır nedir? Ne zaman intihal, ne zaman kopya sayılır?

Başka bir öğrencinin kâğıdına ya da sınavda izin verilmeyen bir kaynağa bakmak kopyadır ve cezalandırılır. Ancak pek çok öğrenci üniversiteye geldiğinde, özellikle ödevlerde neyin kabul edilebilir olduğu ve neyin "kopya" sayıldığı konusunda çok az deneyime sahiptir. Aşağıdaki açıklamalar notlandırılan ödevlerde akademik dürüstlük anlayışını özetler. Aşağıda tanımlanmayan bir durumla karşılaşırsanız, yapmak istediğiniz akademik dürüstlük çerçevesinde kalıp kalmadığınızı öğretim üyesine danışın.

a. Ödev hazırlarken neler kabul edilebilir?

- Ödevi daha iyi anlamak için sınıf arkadaşlarınızla konuşmak.
- İnternette ya da başka bir yerde bulduğunuz fikirleri, alıntıları, paragrafları ya da küçük kod parçalarını, ödevin tamamının çözümü olmamak ve kaynağını belirtmek koşuluyla ödevinize eklemek.
- Ödevinizin dili konusunda yardım istemek.
- Sınıfta tartışma ortamı oluşturmak için ödevinizin küçük parçalarını paylaşmak.
- Teknik sorunları çözmek için internetten ya da başka kaynaklardan talimat, başvuru kaynağı ya da çözüm aramak; ama ödevin doğrudan cevabını aramamak.
- Çözümleri başkalarıyla metin ya da kod paylaşmadan, diyagramlar ya da özet açıklamalarla tartışmak.

- Ödevinizi sizin yerinize yapmaması koşuluyla bir eğitmenden (ücretli ya da ücretsiz) yardım almak.

b. Neler kabul edilemez?

- Kendi çözümünüzü teslim etmeden önce bir sınıf arkadaşınızdan çözümünü görmek istemek.
- Dış kaynaklardan alıp ödevinize kattığınız herhangi bir metnin ya da kodun kaynağını belirtmemek.
- Çözmekte zorlanan bir sınıf arkadaşınıza kendi çözümünüzü vermek ya da göstermek.

J. Beklentiler

Derslere zamanında katılmanız ve haftalık gereksinimleri (okumalar ve proje adımları) tamamlamanız beklenir. Öğretim üyesi ile öğrenciler arasındaki ana iletişim kanalı e-postadır. Sorularınızı üniversite e-posta adresinizden gönderin; **konu satırına ders kodunu, mesaja adınızı yazın**. Öğretim üyesi de gerektiğinde sizinle e-posta ile iletişime geçer; bu yüzden e-postanızı her gün kontrol edin.

K. Ders İçeriği ve İzence Güncellemeleri

Gerektiğinde ders içeriği ya da ders takvimi değiştirilebilir. Bu belge kapsamındaki her değişiklik öğretim üyesi tarafından duyurulur.